Cameroon HRIS/payroll: security and verification evidence

Date: 7 October 2026. Scope: assessment and implementation planning for private-sector SMEs with 10–250 employees. Source baseline: current local working tree; no deployed environment or immutable release candidate was verified. This supporting register informs the consolidated Cameroon-first blueprint; it is not another program roadmap.

Only this report was written by this audit slice. No application code, schema, configuration, database, credentials or plugin settings were changed. ECC `security-review` was read and applied selectively to the existing Better Auth/Prisma architecture; its generic installation, update, Supabase and blockchain examples were not executed or treated as project requirements. Legal conclusions and retention durations belong to the separately researched primary-source requirements matrix and qualified local review.

Overall assessment

Retain the existing server authorization, tenant derivation, own-payslip controls, financial transition ledger and correction mechanisms. Their presence materially changes the plan: harden and prove existing controls instead of rebuilding a generic payroll CRUD system. The largest release gaps are authoritative country provenance, actual private-document delivery, explicit employer scope, current real-database/browser evidence and an operating model that can supply independent actors.

Two concrete scope defects were identified by source inspection. Manager authority is truncated before an individual employee is checked; the profile facade passes `limit: 1`, so even a second valid report can be denied. The directory facade also omits the requested `asOf` date from authority resolution while forwarding it to employee data projection. This mixes current authorization with historical data. Neither finding is a demonstrated live cross-tenant disclosure.

The source review did not establish a presently exploitable cross-tenant disclosure. That limited conclusion is not a penetration-test result. Database constraints, deployed triggers, actual roles, secrets, provider credentials, document storage and browser behavior were not live-tested.

Discovery provenance

Read AGENTS, `docs/ecc/WORKFLOW.md`, `skill-routing.md`, `implementation-status-2026-10-07.md`, `tooling-baseline.json`, the command registry and test-lane guidance. The existing `graphify-out/graph_actions.json` was consulted before architecture tracing. Its `payroll_payroll_control_actions_ts` and `payroll_payroll_control_actions_approveandpostpayrollrunaction` nodes belong to community 5. `GRAPH_REPORT_actions.md` identifies action-test communities 49 (payroll control), 54 (payslip self-service) and 50 (country review intake). These graphs are dated discovery evidence: the combined approval/post action in the older graph has since been replaced by independent actions in current source.

Preserve and reconcile the existing roadmap `docs/HRIS-Payroll/STOQUIFY_HRIS_PAYROLL_REALIZATION_ROADMAP_2026-07-19.md`, including exclusive HRIS writers, immutable snapshots and staged legacy retirement. Do not reset its phases from a new prompt. `what-next/payroll/AQSTOQFLOW_HRIS_PAYROLL_FINAL_READINESS_2026-08-17.md` historically records country-provenance/reviewer blockers and production NO-GO; it is not current gate execution. The October ECC

implementation record separately carries forward real-DB, rendered-browser, native-hook and remote-CI acceptance gaps.

Controls to retain and prove

Boundary	Current source evidence	Meaning and limit
Current server authority	`lib/security/rbac.ts:86` calls Better Auth with `disableCookieCache: true`; `:105` reads the active user by immutable session subject; `:146` checks active organization; `:158` rejects stale session organization; current role permissions are read from persistence.	Preserve revocation-aware authorization. No current production revocation exercise performed.
Protected actions	`services/_shared/protect.ts:55–107` applies optional step-up, `requirePermission`, optional module enforcement and tenant checking.	`handler-derived` deliberately skips generic input tenant extraction. Correctness relies on each handler overwriting organization/actor and each service scoping resource queries. Do not treat the flag itself as a vulnerability or as proof of safety.
Payroll actions	`actions/payroll/payroll-control.actions.ts:118–216` derives organization/actor; review and approval use five-minute fresh auth and enforced payroll-module access.	Preserve direct action denial tests; hiding buttons is insufficient.
HRIS people scope	`services/hris/org.service.ts:154–313` checks requested employee tenant, explicit manage authority, effective reporting relationships and scoped/time-bounded delegations. `prisma/schema.prisma:2884` binds assignment employee, position and org unit with organization-composite foreign keys.	Retain effective relationships and delegated authority. Current-location compatibility is a separate, weaker authority model, not historical reporting proof.
Employee self-service	`services/payroll/payslip-self-service.service.ts:397` resolves the user-linked employee inside the organization and rejects zero/multiple mappings; `:691` filters by organization, linked employee and `EMITTED` status. `actions/payroll/payroll-payslip-self-service.actions.ts:29–87` derives context and requires fresh auth for export.	Own-record permission cannot select another employee through supplied IDs. Export currently returns a watermarked JSON archive, not proof of statutory PDF delivery.
Sensitive HR data	`services/hris/self-service.service.ts:47–164` exposes bounded own-profile/status projections and explicit unavailable capabilities. `services/hris/manager-self-service.service.ts:64` joins scoped directory/inbox/time projections. `services/payroll/__tests__/payroll-privacy.service.test.ts:173–270` asserts salary-read audit and redaction for missing entitlement/permissions.	Preserve separate salary/identifier/payment/document permissions. Mock assertions are not proof that production logs, caches or exports contain no personal data.
Segregated payroll stages	`services/payroll/payroll-control.service.ts:6845` reviewer differs from preparer; `:7002` approver differs from preparer and reviewer; `:7520` poster differs from preparer and approver.	At least three distinct humans/accounts are needed for these stages; the reviewer may also post under existing rules. Do not invent a four-person requirement.
Payment segregation	`services/payroll/payroll-control.service.ts:8668` blocks requester approval; `:8866` requires requester, approver and releaser to be distinct.	SMB onboarding must identify real actors or an authorized external checker. Shared credentials or a wildcard role are not an exception mechanism.

Boundary	Current source evidence	Meaning and limit
Concurrency and replay	`services/payroll/payroll-control.service.ts:1472-1516` uses serializable transition handling; `:6531` binds tenant/idempotency key/run/stage/payload hash; `:6626` checks expected version/status; `:6666` persists compare-and-set transition evidence.	Already implemented, not a greenfield requirement. Test actual competing transactions and rollback, not only mocked call ordering.
Immutable correction	`services/payroll/payroll-control.service.ts:5402-5531` links correction runs to an immutable original and its hashes. June immutability migration plus `prisma/migrations/20260821210000_payroll_trust_spine_transition_ledger/migration.sql:26-132` define retained transitions, constraints and tenant-scoped event/run links.	Do not edit a finalized payslip or overwrite history to repair an error. Deployed trigger existence and runtime behavior are still unverified here.
Country execution	`services/regulatory/regulatory-capability.service.ts:43-85` requires supported capability plus expert/regulator verification for authoritative production; development results are non-authoritative. `services/payroll/payroll-control.service.ts:3075`, `:3212`, `:3970-4022` additionally require reviewed payroll policies/CNPS provenance.	A published pack header or supported subfamily does not establish full Cameroon payroll production readiness. No activation flag was enabled.
Country review intake	`services/payroll/payroll-country-pack-review-intake-persistence.service.ts:251-327` finds tenant-bound retained certificate, requires `READY_FOR_LEGAL_OWNER_SIGNOFF`, source/fixture hashes and fresh authentication.	Retained application approval is not a substitute for genuine qualified-source review or required external signatures.

Actionable gaps and decisions

ID / priority	Finding and evidence	Required action / owner	Acceptance and estimated implementation size
SEC-01 / P1	Legal-employer scope is implicit. Organization has `taxIdentifier` /country (`prisma/schema.prisma:301`), while employees, contracts, periods and runs use `organizationId` ; no dedicated `LegalEntity` or `legalEntityId` was found. `HrisOrgUnit.COMPANY` is an organization-tree category, not an independently identified legal employer.	Product/controller: make one legal employer per tenant an explicit Cameroon pilot condition. Validate its statutory/employer identifiers and establishment mapping. Only add a separate employer dimension if multi-employer-in-one-tenant is an actual requirement.	Two distinct employer fixtures cannot share runs, employees, declarations, payment proofs or accounting periods. One employer with several establishments remains supported without pretending locations are separate legal entities. Scope decision + onboarding contract: 2–4 engineering days after business review; multi-employer migration requires a separate estimate.

ID / priority	Finding and evidence	Required action / owner	Acceptance and estimated implementation size
SEC-02 / P1, basic manager journey	`services/hris/employee.service.ts:136–142` passes `limit: 1` for an individual profile. `services/hris/org.service.ts:218/:242` limits relationship queries, `:252` slices them and `:262` checks the target against that subset. A second legitimate report can be denied. Other callers default to 100; no `orderBy` stabilizes the subset.	HRIS engineer: resolve a targeted employee against the full authorized relationship predicate before pagination; separately cursor-page directory results. Preserve tenant, effective dates and delegation-unit constraints.	Tests for the second report through the profile facade and at 100/101/250 reports, direct and delegated relationships, same-tenant unrelated employee and cross-tenant target; stable paging, no silent omissions. Estimate 1–3 days including query/test review. Source-confirmed; no new regression test was authored in this audit.
SEC-03 / P1 if private document delivery is a launch promise	`services/hris/document-evidence.service.ts:125–138` stores metadata with `rawStorageIntegrated=false` and `downloadAccessIntegrated=false`; `:360–419` denies raw download and returns null URL/token/object key. Scan evidence is supplied metadata, not a verified scanner execution in this service. Searches found request/read functions only in the service/tests; approval is called by the inbox.	HR records/privacy/storage owner: either explicitly launch with metadata-only evidence and an approved external archive procedure, or implement tenant-bound private object storage, server-attested scanning, expiring grants, lawful retention/hold and access audit. Do not turn raw-download availability on from a client-provided hash.	Object A cannot be downloaded by employee B, manager outside scope or foreign tenant; expired/revoked grant denied; correct content hash and scan verdict verified server-side; legal hold prevents purge; retention decision is traceable to approved schedule. Delivery integration estimate 5–10 days after provider/policy choice, excluding legal review.
SEC-04 / P1 operational dependency	Independent actors are mandatory, but the target includes small employers. No reviewed small-team bypass was found in the inspected transition/release paths.	Product/controller/IAM: map preparer, checker/approver and releaser to actual people; allow delegated external professional access through scoped memberships, not shared accounts. Treat any reduced-staff exception as a new risk-approved policy with amount/time scope, compensating review and immutable evidence.	Seeded role matrix proves allowed transitions and denies same-person combinations despite multiple roles. Offboarding/revocation prevents later approval and exact replay access. 2–4 days for role onboarding and tests; policy exception not included in first slice.
SEC-05 / P1 verification	Older payroll child relations are not uniformly organization-composite: `PayrollRunLine` links run/employee by ID (`prisma/schema.prisma:3719`), unlike newer HRIS assignments and transition/event relations. Baseline migration defines separate organization and employee FKs. This does not prove a service-access exploit, but database-level tenant consistency is not guaranteed merely by the presence of `organizationId`.	Security/DB engineer: audit each payroll child relationship and existing migration/trigger coverage. Add real PostgreSQL adversarial cross-tenant insert/update tests before deciding minimal constraint migrations.	Foreign employee/run/period/payslip/payment relationships are refused at the proper boundary; service negatives and direct persistence negatives recorded separately. 2–4 days inventory/test design, migration/backfill separately sized after actual data inventory.
SEC-06 / P1 evidence	Current report-level readiness rests partly on historical gates. `payroll:trust-spine:postgres` prepares/resets a test DB; runtime immutability helper defaults to applying migrations unless instructed otherwise. Existing end-to-end projects depend on auth/fixtures and app server.	QA/platform: provision an explicit disposable target, document intended reset scope, bind results to source/schema/fixture identity, then rerun retained transition, settlement and denial suites.	No skipped suite counted as pass; real concurrency and rollback, EN/FR role denial, export privacy and trusted-provider scenarios accepted separately. 4–8 days after environment availability, excluding provider onboarding and defects.

ID / priority	Finding and evidence	Required action / owner	Acceptance and estimated implementation size
SEC-07 / P2 governance	HRIS actions such as `actions/hris/employee.actions.ts:36–127` and `approval-inbox.actions.ts:49–81` enforce RBAC/step-up but do not specify the payroll module gate. People routes use permission-only `people-route-access.tsx:37–95`; commercial slugs currently have payroll/presence but no HRIS slug. This may be intentional HRIS core packaging.	Product/platform: decide whether People is core or an entitled module, record read-only/offboarding access policy, then enforce the same policy on routes and direct actions. Do not blindly attach payroll entitlement to all People features.	No route/action mismatch under active, trial, read-only and removed subscription states; employee statutory-history access follows the approved policy. 1–3 days after packaging decision. Not asserted as a security bypass without that policy.
SEC-08 / P1 historical authority consistency	`actions/hris/employee.actions.ts:47–57` accepts/passes `asOf`, but `services/hris/employee.service.ts:113–119` drops it from scope resolution; the original input is then passed to source projection, where `services/payroll/employee.service.ts:489` uses the date. Therefore historical projection uses current manager authority. Without explicit `asOf`, `services/hris/org.service.ts:316–350` may also fall back to current `Location.managerId`, while explicit historical resolution otherwise fails closed.	HRIS/IAM: forward the authorized effective date consistently, validate permissible historical access, and reconcile/retire location compatibility under an explicit policy.	Facade-level pre-grant/post-expiry date negatives and valid historical positive; no current-location fallback for historical requests; expired/delegated/terminated managers cannot regain unintended authority. 2–4 days plus employer mapping. Source-confirmed mismatch, not live exploit proof.

Effort ranges assume one engineer with domain-owner review and existing infrastructure. They are planning estimates, not commitments. Prioritize policy/employer scope and country provenance before expanding workflow behavior; fix SEC-02 in a bounded change. Retain the immutable financial kernel while the surrounding evidence and HRIS interfaces are completed.

Required role, route and direct-action denial matrix

Every case below must be checked through the server action/API as well as rendered navigation where a route exists. Replace employee/run identifiers with tenant-owned and foreign fixtures; do not use real employee data for negative tests.

Actor/scenario	Surface	Required outcome and proof
Anonymous, inactive account, locked user, deleted/inactive organization, revoked session	`/[locale]/dashboard/people`, `/people/me`, payroll routes and their direct actions	No employee/payroll payload. Authentication or safe denial response, no sensitive cache reuse. Revocation must be tested while the old signed cookie remains present.
Same-tenant employee	`/people/me`, `/dashboard/payroll/payslips`, `getMyPayrollPayslipsAction`, `prepareMyPayrollPayslipExportAction`	Own mapping only. Forged actor/org fields overwritten or rejected; another employee's payslip ID returns safe not-found/denial. Duplicate mapping fails closed. Only emitted payslips are exposed.
Employee on shared device	Export action and subsequent logout/back navigation	Stale step-up denied before content export; expired/revoked session cannot reuse a grant; browser cache/shared-download handling explicitly accepted. Local downloaded copies are outside server revocation and need user-facing handling policy.

Actor/scenario	Surface	Required outcome and proof
Manager without payroll amount permission	`/people/team`, employee profile, approval inbox, exports	Effective direct/delegated reports only; no salary, raw identifiers or bank values. Second-report and manager101/250 positive cases must succeed; foreign/unrelated employee negative must fail.
Expired delegate or old manager	Same routes + operational-time decisions	Reject after authority expires or assignment changes; historical read requires approved effective-date policy; no accidental location fallback.
HR administrator without payroll role	Employee lifecycle/contract/source actions versus payroll calculate/approve/release	HRIS authority does not grant payment or payroll approval. Source mutations require step-up and should invalidate dependent readiness/approvals where material.
Payroll preparer/reviewer/approver	`reviewPayrollRunAction`, `approvePayrollRunAction`, emission/posting actions	Same-person combinations denied; stale expected version denied; changed payload using old idempotency key denied; exact retry returns retained result without duplicating events or payslips.
Payment requester/approver/releaser/reconciler	Payroll payment preparation/release and settlement	Requester cannot approve; releaser differs from requester/approver. Stale destination or revoked settlement proof blocks. Settled state requires retained evidence, not a manual paid flag.
Foreign-tenant related resource	All employee/contract/run/payslip/batch/evidence lookups	Deny before write/export; no cross-tenant foreign relation accepted. Test service and DB constraints separately.
Inactive/read-only entitlement	Payroll UI and direct action; HRIS per resolved packaging policy	Match allowed historical reads and blocked new writes. Wildcard RBAC does not bypass configured module enforcement.
Draft/unreviewed country pack	Payroll calculation, statutory output, payment/filing adapter	No authoritative production result. Explicit non-authoritative sandbox status; historical pinned pack remains reproducible without retroactively replacing approved snapshots.
Direct database mutation	Finalized run/line/payslip, retained transition, released payment evidence	Update/delete rejected by deployed constraints/triggers; correction creates linked new evidence. Verify as relevant application DB role, not only a mocked client.

Routes currently represented by `tests/e2e/hris-rbac-negative.spec.ts` cover directory/profile/self/team/approvals/history, but inspected route list is EN and captures a denied role. Extend to FR and the positive/negative role matrix above. `tests/e2e/hris-authenticated-release.spec.ts` covers mobile/tablet/desktop but inspected route paths are EN and a fixed fixture. These existing assets are reusable; their existence does not establish current execution or complete employee privacy coverage.

Current executed checks

Check	Result	Evidence class
`node scripts/verify-agent-workflow-contract.js` after script/registry inspection	PASS; 198 package scripts remain outside reviewed manifest	Command/reference integrity only
Three scoped suites listed below	PASS: 3 suites, 17 tests, 16.233 seconds	Mocked unit/action behavior, not actual auth/session/DB/browser
Real PostgreSQL, migrations, seed, provider/authority calls	NOT RUN	No disposable target or live proof established in this slice

Check	Result	Evidence class
Rendered routes, screen reader, actual exports/storage delivery	NOT RUN	Existing infrastructure gaps carried forward
Second-report/pagination and historical-date facade regressions	NOT RUN	Source-confirmed defects; tests belong to implementation phase

Exact scoped invocation:

```
node node_modules/jest/bin/jest.js --config jest.payroll-trust-spine.config.cjs --runInBand --no-cache --roots services/hris/__tests__ actions/payroll/__tests__ --runTestsByPath services/hris/__tests__/org-effective-scope.service.test.ts services/hris/__tests__/document-evidence.service.test.ts actions/payroll/__tests__/payroll-payslip-self-service.actions.test.ts
```

This was a separately inspected unregistered invocation, not inferred safe from a `test` name. The existing config directly uses installed Next/SWC, has no `nextJest` environment-loading wrapper, maps the server-only shim and loads existing `jest.setup.ts` Prisma/router mocks. Roots and exact paths were bounded. Tests use injected/mock scope, auth, storage metadata and business-event clients; no DB runner or `.env` target was invoked. Jest temporary filesystem work is possible. No new test fixture or application file was added.

The 17 assertions include effective tenant/branch/delegation boundaries; raw-document denial and redacted metadata; independent document checker; actor/organization derivation; fresh-auth export and denied module access. They do not prove the unmocked dependency chain or the PostgreSQL optimizer/locks.

Existing suites/runners to reuse next

- `services/payroll/__tests__/payroll-run-approval-transition.service.test.ts`: retained review/approval/emission/posting, stale versions, compare-and-set loss, replay, SoD and legacy combined-command cutover. Source inspected; not rerun in this slice.
- `services/payroll/__tests__/payroll-payslip-self-service.service.test.ts`: own-record output, mismatched payslip, stale export, watermarked archive. Source inspected; not rerun in this slice.
- `services/payroll/__tests__/payroll-tenant-boundary.service.test.ts` and `payroll-privacy.service.test.ts`: mocked tenant lookup and privacy/redaction, with some legacy command coverage. Extend the independent stage surfaces rather than assuming old approval/post tests cover the new actions.
- `scripts/payroll-trust-spine-postgres-certification.js`: real competing approvals and rollback against a dedicated local test database; package wrapper first prepares/resets its target. Do not run against an inferred `.env` target. `scripts/payroll-immutability-runtime-check.js` defaults `applyMigrations=true`; `--skip-migrate` does not make its subsequent fixtures read-only.
- `tests/postgres/ui-workflow/payroll-settlement.test.ts`: real settlement concurrency, replay, partial balance, revoked approval, stale proof, foreign tenant, correction and final-audit-failure rollback. Requires `RUN_UI_WORKFLOW_POSTGRES=1`, `UI_WORKFLOW_POSTGRES_DATABASE` and reviewed local target helper. Prepared posted-source/synthetic-provider fixtures explicitly do not certify original payroll calculation/posting or provider authentication.
- `tests/e2e/hris-rbac-negative.spec.ts`, `hris-authenticated-release.spec.ts`, `payroll-authenticated-smoke.spec.ts`: inspect Playwright project dependencies/auth state, app startup and seed wrappers before use. These write local artifacts and may use mutating fixture setup.

Persistent ECC and UI/UX use

Keep `docs/ecc/WORKFLOW.md` and the command registry authoritative. Add a reviewed HRIS/payroll denial-test lane only after its imports/config/runner scope are accepted; fingerprint the runner/config/helper contract, not all payroll application source. Require security-review on actor/org derivation, manager delegation, sensitive exports, payment destinations, independent approvals and provider callbacks. Record tested invariants and not-run classes in the existing PR evidence fields.

The later HRIS page contract should specify denied/stale/unlinked employee states, explicit compatibility-manager labeling, safe archive status and step-up recovery. UI/UX Pro Max may improve hierarchy/focus/mobile interactions after those controls are fixed; it must not conceal a denied permission behind a zero count or turn an unavailable document/provider feature into a successful-looking action.

Measure improvements with denial-matrix coverage, unresolved leaked-field findings, false manager-denial rate at 2–250 employees, time to resolve an unlinked profile, and current DB/browser evidence age. Do not use total installed skills, mocked test count or one passing gate as the definition of Cameroon production readiness.